UNIT 3 · TOPIC 3.1

Network Vulnerabilities and Attacks

Quiz, Answer Key

Teacher answer key, 18 questions, 1 point each. The correct answer is highlighted; the explanation and distractor notes follow.

1. A network administrator notices that devices on the local area network are forwarding traffic to an attacker-controlled machine instead of the legitimate default gateway. Which type of network attack is most likely responsible?

- ○ A. DNS amplification
- ○ B. Port scanning
- ○ C. Ping flood
- **● D. ARP poisoning**

Correct answer: D

Why: ARP poisoning (ARP spoofing) corrupts the ARP cache of devices on a local network, associating the attacker's MAC address with a legitimate IP (such as the gateway). This redirects local traffic through the attacker's machine, enabling interception or manipulation before forwarding, a classic man-in-the-middle setup.

*Why the others are wrong: **A**, DNS amplification is a volumetric DDoS technique that exploits open DNS resolvers to flood a target; it does not redirect local traffic at layer 2. **B**, Port scanning is a passive reconnaissance technique used to discover open services; it does not redirect or intercept traffic. **C**, A ping flood is a denial-of-service attack using ICMP echo requests to overwhelm a target; it does not cause traffic to be misdirected to an attacker's machine.*

2. Which term correctly describes the estimated severity of harm that would result if a network threat were successfully exploited?

- ○ A. Threat likelihood
- ○ B. Attack vector
- **● C. Risk impact**
- ○ D. Vulnerability window

Correct answer: C

Why: Risk impact refers to the potential harm or consequences that would follow a successful exploit, such as data loss, system downtime, or regulatory penalties. It is one of the two core dimensions of risk evaluation alongside likelihood.

*Why the others are wrong: **A**, Threat likelihood addresses the probability that an attack will occur, not how severe the consequences would be, students often conflate probability with severity. **B**, Attack vector describes the pathway or method an attacker uses to reach a system (e.g., network, adjacent, physical); it is a characteristic of the exploit, not its consequences. **D**, Vulnerability window is not a standard risk management term; students may confuse it with "window of exposure," but it does not map to impact severity.*

3. Which of the following best distinguishes a Distributed Denial of Service (DDoS) attack from a standard Denial of Service (DoS) attack?

- ○ A. DDoS attacks target network-layer protocols, while DoS attacks target application-layer protocols.
- ○ B. DDoS attacks require physical access to the target network, while DoS attacks are carried out remotely.
- **● C. DDoS attacks originate from multiple coordinated sources, while DoS attacks originate from a single source.**
- ○ D. DDoS attacks always result in permanent data loss, while DoS attacks only cause temporary outages.

Correct answer: C

Why: The defining distinction between DoS and DDoS is the number of attack sources. DDoS uses botnets or multiple compromised machines to flood a target simultaneously, making it far harder to filter by source IP. DoS uses a single origin, making it more straightforward to block at the network perimeter.

*Why the others are wrong: **A**, Both DoS and DDoS attacks can target any OSI layer; the protocol layer is a characteristic of the attack technique, not the DoS/DDoS distinction. **B**, Neither DoS nor DDoS requires physical access; both are network-based remote attacks. This is a common misconception conflating physical attacks with DoS. **D**, Neither DoS nor DDoS inherently causes permanent data loss; both primarily target availability (uptime), not data integrity or confidentiality.*

4. A hospital uses an unencrypted guest Wi-Fi network that shares the same broadcast domain as its internal clinical network. A security analyst is evaluating network risks. Which assessment best describes the likelihood and impact of a packet-sniffing attack on this configuration?

○ A. Low likelihood and low impact, because packet sniffing requires physical access to network hardware.

● B. High likelihood and high impact, because sniffing unencrypted wireless traffic can expose patient data to any nearby attacker.

○ C. High likelihood and low impact, because traffic captured on a guest network contains only public-facing data.

○ D. Low likelihood and high impact, because specialized hardware is required to intercept wireless signals.

Correct answer: B

Why: Passive Wi-Fi sniffing requires only a wireless adapter in monitor mode and freely available tools such as Wireshark, the barrier to attack is extremely low, making likelihood high. When a guest network shares a broadcast domain with clinical systems, an attacker can capture traffic containing protected health information (PHI), triggering HIPAA liability and potential patient harm. Both dimensions of risk are therefore high.

*Why the others are wrong: **A**, Wireless packet sniffing is entirely passive and remote; it does not require touching any network hardware. Students may confuse it with wired tap attacks. **C**, If the guest and clinical networks share a broadcast domain, clinical traffic can traverse the same segment as guest traffic, exposing far more than public-facing data. **D**, Passive Wi-Fi sniffing tools are freely available and run on commodity hardware. Specialized equipment is not required, so likelihood cannot be characterized as low.*

5. At Adams County Hospital, an attacker on the internal network launches an ARP spoofing attack targeting communication between nurse workstations and the patient-records file server. Which of the following correctly evaluates the impact of this attack?

● A. The impact is high because the attacker can intercept or alter patient records transmitted between the workstations and the file server.

○ B. The impact is minimal because ARP spoofing only affects internet-facing traffic, not internal server communication.

○ C. The impact is moderate because ARP spoofing is detected and blocked automatically by the web application firewall.

○ D. The impact is low because the file server's TLS encryption prevents captured packets from being read.

Correct answer: A

Why: ARP spoofing operates at OSI layer 2 on the local network. By poisoning the ARP caches of workstations and the file server, the attacker positions themselves as a man-in-the-middle for all traffic between those hosts. If traffic is unencrypted, or if the attacker can downgrade or strip encryption, protected health information

(PHI) can be intercepted, altered, or deleted. This constitutes a high-impact event with HIPAA, patient-safety, and reputational consequences.

*Why the others are wrong: **B**, ARP operates entirely within the local area network at layer 2. It has no visibility into or dependency on internet-facing traffic; this choice fundamentally mischaracterizes how ARP works. **C**, A web application firewall (WAF) operates on HTTP/HTTPS application-layer traffic at the perimeter. It has no visibility into layer 2 ARP broadcasts on an internal network segment. **D**, While TLS protects the confidentiality of data in transit, ARP poisoning can still disrupt availability by redirecting traffic, enable SSL stripping attacks if the TLS implementation is not strictly enforced, or expose metadata. Calling the impact "low" is not warranted.*

6. A security analyst at Adams County Hospital is evaluating two risks for the public appointment-booking web server: (1) IP spoofing to bypass access control lists, and (2) a volumetric DDoS attack. The server sits behind a stateful firewall. Which evaluation of these two risks is most accurate?

○ A. IP spoofing has higher likelihood than DDoS because stateful firewalls do not inspect source addresses.

○ B. Both threats carry equal likelihood because the firewall processes both at the packet level in the same way.

● C. DDoS has higher likelihood and comparable overall risk, because stateful firewalls significantly mitigate IP spoofing but cannot alone stop volumetric flood traffic.

○ D. Neither risk is significant because the appointment-booking server does not store sensitive data.

Correct answer: C

Why: A stateful firewall tracks TCP connection state and validates the three-way handshake, which substantially reduces the effectiveness of IP spoofing attacks (spoofed packets cannot complete the handshake). Volumetric DDoS, however, can exhaust available bandwidth or the firewall's connection-tracking table regardless of stateful inspection, making it the higher-likelihood residual risk. Disrupting the booking server also has measurable patient-access impact.

*Why the others are wrong: **A**, Stateful firewalls do inspect connection state and thereby significantly mitigate simple IP spoofing. This choice inverts the actual defensive effect of stateful inspection. **B**, Stateful firewalls handle connection-based and volumetric traffic very differently; connection tracking protects against spoofed sessions but does not throttle raw volumetric flood traffic. **D**, Availability of the booking server directly affects patient care access. Additionally, booking servers typically log personal and payment information, so a breach could expose personal data.*

7. A hospital security team assesses a compound attack in which an adversary first performs ARP poisoning to position themselves as a man-in-the-middle, then uses packet sniffing to extract credentials from unencrypted HTTP sessions on the clinical network. Which evaluation of this compound threat's overall risk is most accurate?

● A. The compound risk is greater than either individual threat evaluated in isolation, because successful ARP poisoning dramatically raises the likelihood that sniffing will yield high-value credentials.

○ B. The compound risk is equivalent to ARP poisoning alone, since sniffing only becomes useful if the first stage succeeds.

○ C. The compound risk is lower than either individual attack because multi-stage attacks are more complex to execute and therefore less likely to succeed.

○ D. The compound risk is equivalent to sniffing alone because overall risk is determined solely by what data is exposed, not by the method used to reach it.

Correct answer: A

Why: Compound attacks are not additive, they are multiplicative in effect. ARP poisoning lowers the barrier to profitable sniffing by funneling targeted traffic directly through the attacker, raising the probability of credential capture significantly above what sniffing alone from a passive position would achieve. Stolen credentials then enable lateral movement and privilege escalation, amplifying the impact well beyond the initial network communication interception. A complete risk evaluation must account for how the success of stage 1 changes the risk parameters of stage 2.

*Why the others are wrong: **B**, Treating stage 2 as merely conditional on stage 1 understates the combined risk. A complete risk evaluation must account for how the success of one stage changes the parameters, and dramatically raises the expected impact, of the next. **C**, Multi-stage network attacks such as this sequence are well within the capability of moderately skilled threat actors using freely available tooling. Added complexity does not outweigh the substantially increased data access the chain provides. **D**, Method matters for likelihood assessment. Passive sniffing from a random network position versus an ARP-poisoned man-in-the-middle position carry very different probability of yielding targeted, high-value credentials. Risk impact alone is insufficient for a complete evaluation.*

8. A hospital CISO is choosing between two approaches to evaluate the likelihood and impact of network attacks: (A) an AI-powered threat intelligence platform that continuously scans logs and CVE feeds and auto-scores risks, and (B) quarterly manual risk assessments conducted by the security team. Which evaluation of these two approaches is most complete?

○ A. Approach A is strictly superior because AI eliminates human subjectivity from risk evaluation.

○ B. Approach B is strictly superior because risk evaluation requires organizational judgment that AI cannot provide.

○ C. Both approaches yield equivalent risk evaluations as long as both use the same CVE data as their source.

● D. Approach A provides higher timeliness and threat coverage but may generate false positives and lacks organizational context; Approach B provides deeper contextual judgment but may miss rapidly emerging threats between quarterly cycles. A hybrid approach maximizes both coverage and accuracy.

Correct answer: D

Why: This reflects the standard risk management trade-off between automated and manual evaluation. AI tools excel at scale, speed, and continuous monitoring but generate false positives and cannot assess organizational priorities, regulatory obligations, acceptable risk tolerances, or legacy system contexts specific to the hospital. Manual assessment brings contextual depth and human judgment but is bounded by quarterly frequency, leaving an exposure window for rapidly emerging vulnerabilities such as zero-days. A hybrid approach, AI for continuous coverage, analyst review for contextual accuracy, is current best practice.

*Why the others are wrong: **A**, AI-powered tools are known to produce false positives and cannot independently assess organizational context such as HIPAA-specific obligations, acceptable downtime, or whether compensating controls already exist. Human validation is required before AI-generated entries are actionable. **B**, Manual-only quarterly review creates a window during which new vulnerabilities, especially zero-days or actively exploited CVEs, go unevaluated. Manual assessments do not scale in large, complex environments. **C**, The same CVE data processed by different methods yields very different outputs. Timeliness, coverage depth, false-positive rate, and contextual interpretation differ substantially between continuous automated scanning and periodic manual review.*

9. A hospital security committee must prioritize remediation between two identified network risks: Risk X, a known vulnerability in the web application's authentication module (CVSS 7.2, patient-facing, external exposure) and Risk Y, outdated firmware on internal

network switches enabling VLAN hopping (CVSS 6.4, internal network segmentation breach). Analyst capacity allows full remediation of only one risk this quarter. Which prioritization framework is most defensible?

- **● A. Apply a likelihood × impact analysis incorporating organizational context, including data sensitivity, regulatory exposure, existing compensating controls, and exploitability in the current environment, before assigning priority.**
- ○ B. Prioritize Risk Y solely because VLAN hopping could expose the entire internal network.
- ○ C. Prioritize Risk X solely because its CVSS score is numerically higher.
- ○ D. Defer both risks to the next quarterly review cycle since neither has a critical-severity CVSS score above 9.0.

Correct answer: A

Why: CVSS scores are a useful starting point but an incomplete basis for prioritization. CVSS does not account for organizational context: data sensitivity (PHI vs. general data), existing compensating controls (e.g., whether a WAF already mitigates the authentication vulnerability), real-world exploitability in this specific environment, regulatory obligations (HIPAA), and organizational risk tolerance. A complete likelihood × impact analysis incorporating these factors produces a defensible, auditable prioritization decision.

*Why the others are wrong: **B**, The claim that VLAN hopping "could expose the entire internal network" depends on the presence or absence of additional compensating controls. Impact cannot be evaluated without also considering existing mitigations and actual exploitability. **C**, CVSS alone is an internationally recognized but explicitly incomplete risk metric. The CVSS specification itself states that organizations must incorporate environmental and temporal factors for accurate prioritization. **D**, Deferral of known, documented vulnerabilities is itself a risk acceptance decision that must be formally justified. HIPAA's Security Rule requires documented risk management actions; indefinite deferral without justification is not compliant.*

10. Which of the following is a standard component of a risk register used to document network security risks?

- ○ A. Source code for network monitoring scripts
- ○ B. A list of approved vendor contracts
- **● C. The likelihood and impact rating for each identified risk**
- ○ D. Network topology diagrams from the previous fiscal year

Correct answer: C

Why: A risk register is the central artifact for risk documentation. Each entry records the identified risk, its likelihood (probability of occurrence), its impact (severity of consequences), the risk owner, the recommended or implemented mitigations, and the current status. Likelihood and impact ratings are the foundational components that make a risk register actionable.

*Why the others are wrong: **A**, Monitoring scripts are operational artifacts stored in code repositories, not components of a risk register. Students may conflate tooling with documentation. **B**, Vendor contracts are relevant to third-party risk management processes but are not standard components of a network risk register entry. **D**, Network topology diagrams are useful supporting context and are a separate artifact. The risk register records evaluated risk entries, not network maps.*

11. A cybersecurity analyst writes the following: "If an attacker successfully executes a DNS spoofing attack on the hospital's public-facing booking server, patients could be redirected to a fraudulent site that harvests their payment credentials." This statement is best identified as which component of risk documentation?

- **● A. Risk impact statement**
- ○ B. Risk likelihood statement
- ○ C. Risk treatment plan
- ○ D. Residual risk record

Correct answer: A

Why: This statement describes the consequences of a successful attack, what happens if the risk is realized. That is a risk impact statement. It articulates harm (credential harvesting, patient harm, reputational damage) rather than the probability of occurrence, a remediation action, or the risk remaining after controls have been applied.

*Why the others are wrong: **B**, A likelihood statement addresses the probability that the attack will occur (e.g., "DNS spoofing is likely given the absence of DNSSEC"), not what will happen if it does. Students may confuse the two dimensions of risk. **C**, A risk treatment plan describes what controls or actions will be implemented to reduce or accept the risk. No mitigations are mentioned in this statement. **D**, Residual risk is what remains after controls have been applied. This statement makes no reference to any controls, so it cannot describe residual risk.*

12. Which of the following best describes the primary purpose of formally documenting network security risks in a risk register?

- **● A. To enable consistent, informed decision-making about risk prioritization and treatment across the organization**
- ○ B. To provide a legal defense in the event of a data breach lawsuit
- ○ C. To satisfy software licensing requirements for security monitoring tools
- ○ D. To eliminate the need for technical controls by making risks visible to leadership

Correct answer: A

Why: The primary purpose of a risk register is to create a shared, consistent basis for organizational decision-making, ensuring that stakeholders can compare risks, allocate remediation resources, assign accountability, and track treatment status over time. Documentation is a management control that supports and guides technical action; it does not replace it.

*Why the others are wrong: **B**, While documentation can be useful in legal proceedings, this is a secondary benefit. Framing legal defense as the primary purpose mischaracterizes the role of risk management documentation. **C**, Risk documentation has no relationship to software licensing requirements. This distractor tests whether students confuse administrative controls with licensing obligations. **D**, Making risks visible to leadership supports decision-making but does not substitute for technical controls. Documentation is a management-layer control; it must be paired with technical mitigations to be effective.*

13. A network security analyst at Adams County Hospital has confirmed that the hospital's internal network is vulnerable to ARP poisoning due to the absence of Dynamic ARP Inspection on the switches. What information should the analyst document in the risk register for this finding?

- ○ A. The IP addresses of every device on the affected network segment

● **B. The likelihood of the attack, its potential impact on patient data confidentiality and availability, and recommended mitigations such as Dynamic ARP Inspection**

○ C. A full packet capture demonstrating a proof-of-concept ARP poisoning attack

○ D. The vendor name, model number, and purchase date of each network switch on the segment

Correct answer: B

Why: A risk register entry for this vulnerability should capture: the risk description (ARP poisoning via missing Dynamic ARP Inspection), likelihood rating (high, freely available tools, no current detection), impact rating (high, PHI interception, HIPAA liability), risk owner, and recommended treatment (enable Dynamic ARP Inspection, implement encryption in transit). These fields make the entry actionable and auditable.

*Why the others are wrong: **A**, IP address lists belong in asset inventory documentation, not the risk register. The risk register records risk-level information, not network asset enumerations. **C**, A packet capture is evidence produced during penetration testing or incident response. It is a technical artifact stored separately from the risk register. **D**, Switch inventory records belong in asset management systems. Asset details provide useful context but are not components of a risk register entry.*

14. A hospital security team must communicate a newly discovered network vulnerability to two separate audiences: (1) the IT security team responsible for remediation, and (2) hospital administrators who hold budget authority but have no technical background. Which risk documentation approach best serves both audiences?

● **A. Produce a technical risk register entry for the IT team and a separate executive summary translating risk into operational and business impact language for administrators.**

○ B. Produce a single plain-language summary using only business impact language, distributed to both audiences.

○ C. Produce a single highly technical report using protocol-level terminology and CVSS scores, distributed to both audiences.

○ D. Communicate risk findings only through verbal briefings to avoid written documentation being misinterpreted by non-technical administrators.

Correct answer: A

Why: Effective risk documentation tailors content to its audience. The IT team needs technical specificity, attack vectors, affected systems, CVSS metrics, and mitigation steps, to implement controls. Administrators need business and operational impact framing, patient safety risk, regulatory exposure, reputational harm, and cost of inaction, to make informed resource allocation decisions. A single-format document inevitably fails one audience.

*Why the others are wrong: **B**, Plain-language summaries alone lack the technical precision required by IT teams to understand what to fix, which system is affected, and what mitigation to implement. **C**, Technical jargon makes risk documentation inaccessible to administrators, who cannot make effective resource decisions without understanding business impact. **D**, Verbal-only communication cannot be referenced, tracked, audited, or used to demonstrate regulatory compliance. Formal written risk documentation is a requirement in most risk management frameworks including NIST SP 800-30.*

15. After identifying a volumetric DDoS risk on the hospital's public booking server, the security team implements rate-limiting rules on the perimeter firewall. Before marking the risk register entry as closed, which documentation step is required?

● **A. Document the residual risk, the remaining likelihood and impact of DDoS after the rate-limiting control, and record the control as implemented with its implementation date.**

○ B. Delete the original risk entry since the control has been successfully implemented.

○ C. Escalate to the CISO for written sign-off before making any changes to the risk register entry.

○ D. Create a new, separate risk entry for residual risk while leaving the original entry unchanged and open.

Correct answer: A

Why: Implementing a control does not eliminate a risk, it reduces it to a residual level. The risk register entry must be updated to record: (1) the control implemented, (2) its implementation date, (3) the revised likelihood and impact ratings reflecting the control's effect, and (4) the residual risk assessment. The original risk description is retained as part of the audit trail. Rate-limiting reduces but does not eliminate DDoS risk; the residual risk must be explicitly documented.

*Why the others are wrong: **B**, Deleting an entry removes the audit trail and the record of what control was applied and when. Risk register entries are updated and closed with status annotations, never deleted. **C**, CISO escalation may be appropriate for high-severity or policy-level decisions, but it is not a universal prerequisite for updating a risk register entry after implementing a standard control. **D**, Creating duplicate entries fragments the risk record, creates confusion about which entry is authoritative, and inflates the register. Residual risk is documented within the existing entry as an update, not as a new record.*

16. A hospital security analyst documents a network risk as follows: "Risk: ARP poisoning. Likelihood: High. Impact: High." The analyst marks the entry complete. Which evaluation of this documentation practice is most accurate?

○ A. The documentation is complete because likelihood and impact are the two core components of risk evaluation.

○ B. The documentation is incomplete only because it lacks a CVSS severity score for the vulnerability.

● **C. The documentation is incomplete because it omits the risk owner, affected assets, recommended mitigations, and residual risk, all of which are required for an actionable risk register entry.**

○ D. The documentation is complete and appropriately brief; risk registers should avoid excessive detail to prevent information overload.

Correct answer: C

Why: Likelihood and impact ratings are necessary but not sufficient for an actionable risk register entry. Without a risk owner, there is no accountability. Without affected assets, the IT team does not know what to protect. Without recommended mitigations, the entry cannot drive remediation. Without residual risk, the entry cannot be closed responsibly. The entry as written is passive data, not an actionable management record.

*Why the others are wrong: **A**, Likelihood and impact are foundational, but a risk register entry requires additional fields to be operationally useful. A two-field entry cannot drive remediation, accountability, or regulatory compliance. **B**, CVSS scores are one way to quantify risk dimensions and are useful context, but they are not universally required in all risk register formats. The missing fields, owner, assets, mitigations, residual risk, are more functionally critical than a CVSS score. **D**, Conciseness in writing is valuable, but omitting required fields is not brevity, it is incompleteness. Risk registers must be actionable; a two-line entry for a high-impact, high-likelihood threat is operationally negligent.*

17. A hospital CISO is evaluating whether to use an AI-powered vulnerability scanner that auto-populates risk register entries from CVE feeds and log analysis, or to rely on manual analyst documentation of network risks after each assessment. Which evaluation of these two documentation approaches is most complete?

○ A. AI-generated entries are always preferable because they eliminate human subjectivity and bias from risk documentation.

○ B. Manual documentation is always preferable because risk registers require organizational judgment that AI is incapable of providing.

● C. AI-generated entries offer speed and coverage but require analyst validation for accuracy and organizational context; manual entries are more contextually accurate but do not scale and leave gaps between assessment cycles. A hybrid approach combining both maximizes both coverage and documentation quality.

○ D. The documentation method is irrelevant provided both approaches populate the same fields, likelihood, impact, and mitigation, in the register.

Correct answer: C

Why: AI tools can rapidly populate risk registers with technical data (CVE references, affected systems, CVSS scores) at scale and continuously, but they produce false positives and cannot assess organizational priorities, HIPAA-specific obligations, risk tolerance, or the existence of compensating controls in the specific environment. Manual analyst documentation captures this context but is resource-intensive and creates exposure windows between assessment cycles. A hybrid model, AI for continuous coverage, analyst review for contextual accuracy and completeness, represents current best practice in risk documentation.

*Why the others are wrong: **A**, AI-generated entries require human validation before being actionable. AI tools produce false positives, cannot assess organizational context or regulatory obligations, and may misclassify risk severity for organization-specific environments. **B**, Manual-only documentation does not scale in large environments and creates exposure windows between quarterly or annual assessments during which newly disclosed vulnerabilities go undocumented. **D**, The documentation method significantly affects accuracy, timeliness, false-positive rate, and contextual richness of entries. Two entries with the same field names populated by different methods can have dramatically different quality and utility.*

18. A hospital security team simultaneously identifies three network risks: (1) ARP poisoning vulnerability on the internal LAN, (2) a volumetric DDoS exposure on the public web server, and (3) an outdated TLS configuration on the patient-records file server. Analyst capacity is limited. Which risk documentation and prioritization strategy is most defensible from a risk management standpoint?

○ A. Document all three risks with equal priority since simultaneous identification requires equal treatment in the register.

● B. Document all three risks fully in the register, then apply a likelihood × impact matrix incorporating organizational context to assign priority, scheduling review dates for lower-priority items to ensure they are not neglected.

○ C. Document only the highest-impact risk to avoid overwhelming the risk register with entries during a capacity-constrained period.

○ D. Escalate all three risks immediately to external security consultants since simultaneous identification indicates a systemic failure exceeding internal capacity.

Correct answer: B

Why: Responsible risk documentation requires that all identified risks be recorded regardless of capacity constraints, omitting risks to save time creates audit

gaps, regulatory exposure, and untracked liability. Once documented, a likelihood × impact matrix applied with organizational context (data sensitivity, existing controls, regulatory obligations, exploitability) produces a defensible, auditable prioritization. Scheduling review dates for lower-priority items ensures they receive treatment within a defined timeframe rather than being forgotten.

*Why the others are wrong: **A**, Equal priority treatment ignores risk magnitude. Allocating the same resources to a critical PHI exposure and a lower-severity exposure is both inefficient and indefensible; risk management exists precisely to enable differential prioritization. **C**, Omitting lower-priority risks from the register creates an incomplete audit trail, exposes the organization to untracked liability, and violates the documentation requirements of frameworks such as NIST SP 800-30 and HIPAA's Security Rule. Capacity constraints affect remediation timelines, not documentation completeness. **D**, Simultaneous identification of multiple risks is normal in active security programs, not necessarily a systemic failure. External escalation may be appropriate for specific high-severity items after internal prioritization, but is not the first response to routine multi-risk documentation.*